

CO3 – AT1: Enumeration Analysis

Answer-Preparation Study Outline

Course: Ethical Hacking (ITA14) | Course Outcome: CO3 | Total Marks: 100 | Weightage: 40%

This outline is a study aid, not a completed answer sheet. Use it to build your own report with your own scan output, screenshots, and analysis, then complete the Code of Conduct declaration yourself.

Question 1: Full Enumeration of scanme.nmap.org

Target: scanme.nmap.org (public authorized Nmap test target)

Perform host discovery, TCP port scanning, service version detection, OS fingerprinting, and default script scanning; analyze the business purpose of each service, its necessity for public access, and how a threat actor could exploit enumeration data.

Concepts you need to understand

- Host discovery vs. port scanning are different phases — discovery just confirms the host is up.
- Service version detection (-sV) fingerprints exact software/version from responses.
- OS fingerprinting (-O) uses TCP/IP stack quirks to guess the operating system.
- NSE default scripts (-sC) run safe, commonly useful enumeration scripts automatically.
- 'Necessary for public access' — evaluate whether each open service should reasonably face the internet.

Nmap commands to reference (run only against the authorized lab target)

```
nmap -sn scanme.nmap.org
nmap -p- -T4 scanme.nmap.org
nmap -sV -O -sC scanme.nmap.org
```

What your analysis should cover

- List every open port, service, and version detected.
- For each, state its business purpose and whether public exposure is justified (this host is intentionally exposed for testing, so discuss that context too).
- Explain, per-service, how a threat actor could use it: brute-force targets, known-CVE exploitation, further service fingerprinting.
- Summarize the overall attack-surface size and risk level for this host.
- Recommend hardening steps appropriate to a public-facing host.

Mapping to the rubric

Conceptual Understanding (20%):

Show you understand what each Nmap scan type/flag actually does, not just that you ran it.

Model/Report Design (25%):

Structure your report logically: methodology → results → analysis → recommendations.

Tool Usage (20%):

Use the correct Nmap flags for the task and show real command output/screenshots.

Analysis of Results (20%):

Interpret findings — explain the 'so what', not just list ports.

Documentation (15%):

Clear headings, tables, and consistent formatting throughout.

Question 2: Comprehensive Enumeration of Metasploitable 2

Target: 192.168.56.101 (Metasploitable 2, isolated lab)

Identify all open ports, services, versions, and OS info; analyze which services are potential entry points; categorize services into High/Medium/Low risk; explain how results guide attack-vector selection.

Concepts you need to understand

- Metasploitable 2 is intentionally vulnerable — expect many legacy/insecure services.
- Risk categorization criteria: exposure (is it network-facing by default), known vulnerability history, and impact if compromised.
- Understand common Metasploitable services: FTP (vsftpd backdoor history), Telnet, rlogin, NFS, Samba, MySQL, distccd, etc.

Nmap commands to reference (run only against the authorized lab target)

```
nmap -sn 192.168.56.101
nmap -p- -T4 192.168.56.101
nmap -sV -O -sC -p<open-ports> 192.168.56.101
```

What your analysis should cover

- Build a full inventory: port | service | version.
- Categorize each into High/Medium/Low risk with a one-line justification per item.
- Explain which services are the most attractive initial entry points and why (e.g., unauthenticated access, known backdoors, outdated versions).
- Describe how a penetration tester would sequence attacks based on this enumeration (highest-value/easiest targets first).

Mapping to the rubric

Conceptual Understanding (20%):

Show you understand what each Nmap scan type/flag actually does, not just that you ran it.

Model/Report Design (25%):

Structure your report logically: methodology → results → analysis → recommendations.

Tool Usage (20%):

Use the correct Nmap flags for the task and show real command output/screenshots.

Analysis of Results (20%):

Interpret findings — explain the 'so what', not just list ports.

Documentation (15%):

Clear headings, tables, and consistent formatting throughout.

Question 3: Windows Workstation Enumeration

Target: 192.168.56.102 (Windows workstation, pre-production check)

Enumerate active ports, network services, file-sharing protocols, remote management services, and OS details; assess compliance with least privilege; discuss reconnaissance/lateral-movement/unauthorized-access risk; propose hardening.

Concepts you need to understand

- Least privilege principle: a service should only run/be exposed if it's actually needed for the machine's role.
- Common Windows enumeration targets: SMB (445/139), RDP (3389), WinRM (5985/5986), NetBIOS.
- SMB/NetBIOS enumeration can reveal shares, usernames, and OS/domain info — high value for attackers.

Nmap commands to reference (run only against the authorized lab target)

```
nmap -sn 192.168.56.102
nmap -p- -T4 192.168.56.102
nmap -sV -O --script smb-os-discovery,smb-enum-shares 192.168.56.102
```

What your analysis should cover

- List discovered ports/services and identify which relate to file sharing vs. remote management vs. general networking.
- Assess each against least privilege — flag anything that shouldn't be exposed on a production-bound workstation.
- Explain how an attacker could use SMB/RDP findings for lateral movement or credential attacks.
- Propose specific hardening: disable unused services, restrict SMB/RDP to management VLAN, enforce NLA on RDP, patch level checks.

Mapping to the rubric

Conceptual Understanding (20%):

Show you understand what each Nmap scan type/flag actually does, not just that you ran it.

Model/Report Design (25%):

Structure your report logically: methodology → results → analysis → recommendations.

Tool Usage (20%):

Use the correct Nmap flags for the task and show real command output/screenshots.

Analysis of Results (20%):

Interpret findings — explain the 'so what', not just list ports.

Documentation (15%):

Clear headings, tables, and consistent formatting throughout.

Question 4: Web Service Enumeration – OWASP Juice Shop Server

Target: 192.168.56.103 (OWASP Juice Shop, pre-pentest recon)

Perform host discovery, port scanning, service version detection, OS fingerprinting, and web service identification; analyze how services support the web app; evaluate exposure risk of web/admin/supporting services.

Concepts you need to understand

- Web service identification goes beyond port 80/443 — check for exposed admin panels, APIs, or supporting services (databases, management ports).
- Understanding what 'supports the hosted web application' means: web server software, backend API ports, any exposed database ports.
- How enumeration results feed directly into a subsequent web-application penetration test (Question 2 of the CO4-AT01 set is closely related).

Nmap commands to reference (run only against the authorized lab target)

```
nmap -sn 192.168.56.103
nmap -p- -T4 192.168.56.103
nmap -sV -O -sC -p80,443,3000,8080 192.168.56.103
```

What your analysis should cover

- List all discovered services and identify which directly serve the web application vs. supporting infrastructure.
- Evaluate risk of anything exposed beyond the core web port (e.g., an accidentally exposed database or admin interface).
- Explain how this enumeration data would guide the vulnerability-assessment phase (e.g., knowing the exact web stack narrows which vulnerabilities to test for).
- Recommend exposure-minimization steps: close unnecessary ports, put admin interfaces behind VPN/allow-list.

Mapping to the rubric

Conceptual Understanding (20%):

Show you understand what each Nmap scan type/flag actually does, not just that you ran it.

Model/Report Design (25%):

Structure your report logically: methodology → results → analysis → recommendations.

Tool Usage (20%):

Use the correct Nmap flags for the task and show real command output/screenshots.

Analysis of Results (20%):

Interpret findings — explain the 'so what', not just list ports.

Documentation (15%):

Clear headings, tables, and consistent formatting throughout.

Question 5: Gateway Device Enumeration

Target: 192.168.56.1 (network gateway)

Conduct port scanning, service detection, OS fingerprinting, and script-based enumeration; identify exposed management interfaces; analyze security implications of SSH/Telnet/SNMP/HTTP(S) management exposure; recommend controls.

Concepts you need to understand

- A compromised gateway can expose the entire network behind it — this makes gateway hardening especially critical.
- Management protocol risk: SNMP with default community strings, Telnet in plaintext, unauthenticated HTTP admin panels.
- NSE scripts can enumerate SNMP info, HTTP titles, and default credentials on management interfaces.

Nmap commands to reference (run only against the authorized lab target)

```
nmap -sn 192.168.56.1
nmap -p- -T4 192.168.56.1
nmap -sV -O --script snmp-info,http-title,banner 192.168.56.1
```

What your analysis should cover

- List every management-related service found and its exposure state.

- Discuss the specific risk of each (e.g., SNMP community-string guessing, Telnet credential sniffing, weak HTTP admin auth).
- Explain how an attacker exploiting the gateway could pivot into the internal network.
- Recommend controls: disable Telnet/SNMPv1-2c, use SSH/SNMPv3, restrict management interface to a dedicated admin VLAN, enable logging/alerting on management access.

Mapping to the rubric

Conceptual Understanding (20%):

Show you understand what each Nmap scan type/flag actually does, not just that you ran it.

Model/Report Design (25%):

Structure your report logically: methodology → results → analysis → recommendations.

Tool Usage (20%):

Use the correct Nmap flags for the task and show real command output/screenshots.

Analysis of Results (20%):

Interpret findings — explain the 'so what', not just list ports.

Documentation (15%):

Clear headings, tables, and consistent formatting throughout.

General Write-Up Checklist Before Submission

- Real scan output/screenshots for scanme.nmap.org and each assigned lab IP.
- A findings table per question: Port | Service | Version | Risk Level.
- An explicit 'attacker's perspective' paragraph per question, since the assessment repeatedly asks for this.
- A clear recommendations section per question, tied to what you actually found.
- Your name/reg. no. filled into the Code of Conduct and signed.